

TÀI LIỆU THAM KHẢO KHÓA LUẬN

TỔNG HỢP Ý TƯỞNG VÀ KỸ THUẬT CỦA CÁC HỆ THỐNG CHỐNG LỪA ĐẢO TRỰC TUYẾN

*Phục vụ đề tài: Xây dựng nền tảng web kiểm tra và cảnh báo rủi ro lừa đảo trực tuyến
trong giao dịch đời sống bằng Java Backend*

Mục	Nội dung
Định hướng	Ứng dụng thực tế - Java Backend - Web Security
Nội dung chính	Các website/app đã có, kỹ thuật họ sử dụng, ý tưởng nghiên cứu liên quan và hướng áp dụng vào đề tài
Công nghệ gợi ý	Java 17+, Spring Boot, PostgreSQL, Redis, React/Next.js, Docker
Ngày tổng hợp	19/06/2026

Ghi chú quan trọng

Tài liệu này chỉ tổng hợp thông tin công khai và suy luận kỹ thuật hợp lý từ chức năng mà các hệ thống công bố.

Không khẳng định biết thuật toán nội bộ, dữ liệu riêng hoặc cách triển khai chi tiết của từng nền tảng. Mục tiêu là dùng làm tài liệu tham khảo để xây dựng phiên bản khóa luận bằng Java Backend, không sao chép sản phẩm thương mại hay hệ thống của bên thứ ba.

Người thực hiện:

Lớp/MSSV:

1. Mục đích của tài liệu

Tài liệu này trình bày các nền tảng, website, ứng dụng và hướng nghiên cứu đã có liên quan đến việc phát hiện lừa đảo trực tuyến, phishing URL, website giả mạo, số điện thoại/số tài khoản rủi ro và báo cáo cộng đồng.

Từ đó, tài liệu rút ra các ý tưởng và kỹ thuật phù hợp để đưa vào đề tài khóa luận: một nền tảng web dùng Java Backend giúp người dùng kiểm tra link, biểu mẫu, tin nhắn giao dịch, số điện thoại và số tài khoản trước khi thực hiện hành động rủi ro.

Kết luận nhanh

Đã có nhiều hệ thống làm một phần bài toán này, ví dụ: kiểm tra link, blacklist website, báo cáo cộng đồng, kiểm tra tài khoản ngân hàng, kiểm tra số điện thoại hoặc đánh giá trust score của website. Đề tài khóa luận vẫn hợp lý nếu xác định phạm vi là xây dựng một phiên bản học thuật/demo bằng Java Spring Boot, kết hợp các kỹ thuật phổ biến vào một kiến trúc phần mềm rõ ràng.

2. Các website/app đã có và ý tưởng chính

Bảng dưới đây tổng hợp các hệ thống tiêu biểu ở Việt Nam và quốc tế. Các kỹ thuật được ghi theo mức độ công khai của tài liệu chính thức, kết hợp với suy luận kỹ thuật phổ biến trong lĩnh vực phát hiện phishing/scam.

Hệ thống	Ý tưởng chính	Kỹ thuật/chức năng công khai	Bài học cho đề tài
ChongLuaDao.vn (Việt Nam)	Cộng đồng chống lừa đảo, tiện ích trình duyệt, danh sách chặn	Dùng extension trình duyệt để cảnh báo khi truy cập website nguy hiểm; tích hợp dữ liệu danh sách chặn vào một số nền tảng khác. [5]	Học cách kết hợp dữ liệu cảnh báo + tiện ích người dùng + báo cáo cộng đồng.
Tín Nhiệm Mạng (Việt Nam)	Hệ sinh thái xác thực website/tổ chức và danh sách website giả mạo	Công bố danh sách đen website/mạng xã hội giả mạo, có bộ lọc theo lĩnh vực, tình trạng, loại đối tượng; có cơ chế báo cáo thông tin giả mạo. [6]	Áp dụng ý tưởng danh sách đen, trạng thái xử lý, phân loại lĩnh vực và quản trị dữ liệu rủi ro.
Tín Nhiệm Mạng - Tra cứu tài khoản	Tra cứu số tài khoản ngân hàng được báo cáo	Tài khoản có trạng thái như lừa đảo, an toàn, đang xác minh; người dùng có thể bình luận/vote. [7]	Áp dụng vào module Phone/Bank Account Checker và Community Report.
nTrust (Việt Nam)	Ứng dụng phòng chống lừa đảo	Kiểm tra số điện thoại, link website, số tài khoản, mã QR và ứng dụng đáng ngờ. [8]	Cho thấy nhu cầu thực tế: người dùng muốn kiểm tra nhiều loại dữ liệu, không chỉ URL.
Google Safe Browsing	Dịch vụ kiểm tra URL nguy hiểm	Cho ứng dụng kiểm tra URL theo danh sách website không an toàn được cập nhật, gồm phishing/deceptive sites, malware và unwanted software. [1]	Áp dụng ý tưởng threat intelligence, blacklist/hash lookup, cảnh báo theo mức nguy hiểm.
PhishTank	Kho dữ liệu phishing do cộng đồng đóng góp	Người dùng có thể submit, verify, track và chia sẻ dữ liệu phishing; có API miễn phí. [2]	Áp dụng luồng: user report -> verify -> đưa vào danh sách cảnh báo.
VirusTotal	Tổng hợp phân tích từ nhiều engine bảo mật	URL/domain có báo cáo threat reputation/context từ nhiều antivirus, blacklist và công cụ bảo mật; có community reputation. [3][4]	Áp dụng ý tưởng gom nhiều tín hiệu, không chỉ một luật duy nhất.
ScamAdviser	Website reputation/scam checker	Dùng thuật toán để đánh giá website là hợp pháp, phishing hay bán hàng giả; mục tiêu hỗ trợ người tiêu dùng ra quyết định online. [9]	Áp dụng ý tưởng trust score, giải thích ngắn gọn và khuyến nghị cho người dùng phổ thông.
CheckPhish	URL scanner, email scanner, typosquat/lookalike monitoring	Cho phép scan URL đáng ngờ, theo dõi typosquat và domain gần giống thương hiệu. [10]	Áp dụng module Domain Similarity / Typosquatting Analysis.

3. Các kỹ thuật thường được dùng

3.1. Blacklist, whitelist và threat intelligence

Đây là kỹ thuật nền tảng nhất. Hệ thống kiểm tra URL, domain, số điện thoại, số tài khoản hoặc từ khóa có nằm trong danh sách rủi ro hay không. Google Safe Browsing, Tín Nhiệm Mạng, PhishTank và VirusTotal đều thể hiện rõ hướng dùng dữ liệu cảnh báo, danh sách độc hại hoặc báo cáo đã xác minh. [1][2][3][6]

- Blacklist: danh sách URL/domain/số tài khoản/số điện thoại đã bị đánh dấu rủi ro.
- Whitelist: danh sách website/tổ chức đáng tin cậy để giảm cảnh báo sai.
- Threat intelligence: dữ liệu rủi ro từ nhiều nguồn, có thể cập nhật định kỳ.
- Trong khóa luận: xây bảng RiskEntity và RiskSource để lưu loại rủi ro, nguồn báo cáo, trạng thái xác minh và điểm uy tín.

3.2. Báo cáo cộng đồng và kiểm duyệt

PhishTank cho phép cộng đồng submit/verify phishing; Tín Nhiệm Mạng có báo cáo thông tin giả mạo và tra cứu tài khoản có bình luận/vote; VirusTotal có community score dựa trên vote của người dùng có reputation. [2][4][6][7]

- Luồng đề xuất: User gửi báo cáo -> Admin xem bằng chứng -> Duyệt/Từ chối -> Nếu duyệt thì cập nhật RiskEntity.
- Trạng thái nên có: PENDING, VERIFIED, REJECTED, RESOLVED.
- Chống spam báo cáo: giới hạn tần suất, audit log, điểm uy tín người báo cáo.

3.3. Rule Engine chấm điểm rủi ro

Rule Engine là kỹ thuật rất phù hợp với khóa luận Java Backend vì dễ giải thích, dễ kiểm thử và có thể cấu hình bởi quản trị viên. Thay vì chỉ trả lời 'an toàn' hoặc 'nguy hiểm', hệ thống cộng điểm theo từng dấu hiệu.

Luật ví dụ	Điểm	Ý nghĩa
URL nằm trong blacklist	+40	Rủi ro rất cao vì đã có dữ liệu cảnh báo.
Domain gần giống thương hiệu thật	+25	Dấu hiệu phishing/typosquatting.
Không dùng HTTPS hoặc SSL lỗi	+10 đến +20	Rủi ro khi nhập thông tin nhạy cảm.
Redirect qua nhiều domain lạ	+15	Có thể che giấu điểm đến thật của link.
Form yêu cầu OTP/mật khẩu/CCCD/số thẻ	+25	Dữ liệu nhạy cảm không nên nhập vào trang lạ.
Tin nhắn có yếu tố gấp gáp, trúng thưởng, khóa tài khoản	+10 đến +20	Dấu hiệu lừa đảo phổ biến trong SMS/Zalo/email.
Số tài khoản/số điện thoại bị báo cáo nhiều lần	+30 đến +50	Tín hiệu cộng đồng mạnh.

Phân loại gợi ý: 0-29 điểm = An toàn tương đối; 30-59 điểm = Cần cẩn trọng; 60-100 điểm = Rủi ro cao.

3.4. Phân tích URL và domain

Nhiều nghiên cứu và công cụ phishing tập trung vào URL vì có thể phát hiện rủi ro trước khi người dùng nhập dữ liệu. CheckPhish công bố chức năng scan URL và theo dõi typosquat/lookalike domain; PhishMatch nghiên cứu cách phát hiện các biến thể cybersquatting bằng matching nhiều lớp. [10][14]

- Kiểm tra domain dài bất thường, nhiều dấu gạch ngang, nhiều subdomain, ký tự dễ gây nhầm lẫn.
- Tính độ giống với domain/thương hiệu thật bằng Levenshtein Distance hoặc n-gram similarity.
- Phát hiện URL shortener và theo dõi redirect để biết đích cuối cùng.
- So sánh với danh sách brand/domain tin cậy để phát hiện giả mạo.

3.5. Kiểm tra redirect, HTTPS, SSL và security headers

OWASP nêu rõ unvalidated redirect có thể bị lợi dụng để triển khai phishing và đánh cắp thông tin đăng nhập. OWASP cũng có cheat sheet về HTTP security headers, nhấn mạnh các header giúp giảm rủi ro như XSS, clickjacking và rò rỉ thông tin. [11][12]

- Redirect analysis: đếm số lần chuyển hướng, kiểm tra đổi domain, ghi lại redirect chain.
- HTTPS/SSL check: kiểm tra có HTTPS, chứng chỉ hợp lệ, thời hạn chứng chỉ.
- Header check: kiểm tra Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options.
- Lưu ý: thiếu header không đủ kết luận lừa đảo, nhưng là một tín hiệu cộng điểm rủi ro.

3.6. Phân tích HTML và biểu mẫu

Với Java, jsoup là thư viện phù hợp để lấy, parse, trích xuất và thao tác HTML/XML bằng DOM API, CSS selector và XPath selector. [13]

- Đếm số form và input nhạy cảm: password, otp, pin, card, cccd, bank, phone.
- Kiểm tra action của form gửi về domain nào, có khác domain đang hiển thị không.
- Tìm từ khóa dụ dỗ/khẩn cấp trong nội dung trang: xác minh ngay, tài khoản bị khóa, nhận thưởng, hoàn tiền.
- Không lưu dữ liệu nhạy cảm người dùng nhập; chỉ phân tích cấu trúc và nội dung công khai.

3.7. Phân tích nội dung tin nhắn/giao dịch

Đây là phần mở rộng từ hướng scam warning. Hệ thống cho người dùng dán tin nhắn, bài đăng hoặc đoạn hội thoại để phân tích dấu hiệu lừa đảo trong đời sống.

- Keyword matching: phát hiện từ khóa trùng thưởng, xác minh, khóa tài khoản, chuyển tiền gấp, đặt cọc trước.
- Pattern extraction: tách URL, số điện thoại, số tài khoản, số tiền, thời hạn, mã OTP nếu có.
- Rule scoring: kết hợp nhiều dấu hiệu để ra điểm rủi ro.
- AI/NLP có thể đưa vào hướng phát triển, chưa cần làm ở phiên bản khóa luận cơ bản.

3.8. Trust score, giải thích và khuyến nghị

ScamAdviser tập trung vào việc trả lời câu hỏi website có an toàn hay là scam/phishing để hỗ trợ người tiêu dùng; VirusTotal hiển thị kết quả theo nhiều engine và community score. [3][4][9]

- Kết quả nên gồm: điểm rủi ro, mức cảnh báo, lý do, bằng chứng kỹ thuật, khuyến nghị hành động.
- Ví dụ giải thích: 'Domain gần giống ngân hàng thật, form yêu cầu OTP và số tài khoản đã có 3 báo cáo trong 7 ngày gần nhất.'
- Cách trình bày dễ hiểu giúp đề tài gần với người dùng phổ thông, không chỉ là công cụ kỹ thuật.

4. Ý tưởng từ nghiên cứu và dự án của người khác

Nghiên cứu/dự án	Ý tưởng	Kỹ thuật	Ứng dụng vào đề tài
PhishMatch	Phát hiện phishing URL theo hướng nhiều lớp	Exact string matching, approximate matching, whitelist, ngữ cảnh truy cập và machine learning. [14]	Có thể học ý tưởng phân tích domain gần giống và dùng whitelist để giảm false positive.
WebPhish	Phát hiện phishing bằng đặc trưng URL và HTML	Dùng raw URL + HTML characteristics, mô hình deep learning để học mẫu phishing. [15]	Đưa vào hướng phát triển AI/ML; bản cơ bản dùng rule + HTML parsing trước.
PhishChain	Blacklist phi tập trung và minh bạch	Crowdsourced assessment, blockchain/ledger, điểm phishing và điểm kỹ năng người tham gia. [16]	Lấy ý tưởng điểm uy tín người báo cáo, lịch sử kiểm duyệt minh bạch.
Nghiên cứu lớn về VirusTotal	Tổng hợp nhiều scanner có thể nhiều và bất đồng	Nghiên cứu chỉ ra kết quả từ nhiều scanner cần được xử lý cẩn thận, không chỉ dùng ngưỡng cố định hoặc majority vote đơn giản. [17]	Khi dùng nhiều tín hiệu, cần trọng số và giải thích, tránh kết luận tuyệt đối.

5. Hướng áp dụng vào đề tài khóa luận

Đề tài nên chọn phạm vi vừa sức: không cố làm một hệ thống lớn như Google Safe Browsing hoặc VirusTotal, mà xây dựng một nền tảng web demo có kiến trúc rõ, dữ liệu mẫu, chức năng đầy đủ và khả năng mở rộng.

5.1. Phiên bản bắt buộc nên làm

- User/Auth: đăng ký, đăng nhập, JWT, phân quyền USER/ADMIN.
- URL Scanner: kiểm tra URL, domain, HTTPS, redirect, blacklist/whitelist.
- Form Analyzer: lấy HTML bằng Java HttpClient + jsoup, phân tích form và input nhạy cảm.
- Transaction Text Analyzer: phân tích tin nhắn/bài đăng giao dịch bằng keyword + pattern + rule.
- Phone/Bank Account Checker: tra cứu trong database rủi ro và lịch sử báo cáo.
- Rule Engine: tính điểm rủi ro dựa trên luật và trọng số.
- Community Report: người dùng gửi báo cáo, admin kiểm duyệt.
- Admin Dashboard: thống kê, quản lý rule, risk entity, report.
- PDF/HTML Report: xuất kết quả kiểm tra hoặc báo cáo thống kê.

5.2. Phần nên để mở rộng

- AI/LLM phân tích nội dung tin nhắn phức tạp.
- OCR đọc ảnh chụp màn hình tin nhắn hoặc giao dịch.
- Browser extension cảnh báo khi người dùng truy cập link đáng ngờ.
- Tích hợp dữ liệu public API như Safe Browsing/PhishTank nếu điều kiện sử dụng cho phép.
- Hệ thống reputation nâng cao cho người báo cáo và người xác minh.

6. Kiến trúc kỹ thuật đề xuất

Sơ đồ logic

Người dùng -> Frontend Web -> REST API Spring Boot -> Các module phân tích -> Rule Engine -> Database/Cache -> Kết quả cảnh báo
Admin -> Dashboard -> Quản lý rule/risk entity/report -> Xuất báo cáo PDF/HTML

Thành phần	Công nghệ	Vai trò
Frontend Web	ReactJS hoặc Next.js	Giao diện nhập link/tin nhắn/số tài khoản, xem kết quả và lịch sử.
Backend API	Java 17+, Spring Boot	Controller - Service - Repository, xử lý nghiệp vụ và REST API.
Security	Spring Security, JWT, BCrypt	Đăng nhập, phân quyền USER/ADMIN, bảo vệ API.
URL Scanner	Java HttpClient, Apache Commons Validator	Chuẩn hóa URL, kiểm tra redirect, HTTPS, domain.
Form Analyzer	jsoup	Parse HTML, phát hiện form/input nhạy cảm.
Text Analyzer	Regex, keyword matching	Tách link/số điện thoại/số tài khoản, phát hiện từ khóa lừa đảo.
Rule Engine	Java service + bảng RiskRule	Tính điểm rủi ro theo luật cấu hình được.
Database	PostgreSQL, JPA/Hibernate	Lưu User, ScanRequest, RiskResult, RiskEntity, ScamReport, RiskRule.
Cache	Redis	Cache domain/số tài khoản/từ khóa rủi ro truy vấn nhiều.
Report	OpenPDF/JasperReports	Sinh báo cáo PDF/HTML cho kết quả kiểm tra và dashboard.

Deploy	Docker, Docker Compose, Nginx	Triển khai demo để lặp lại.
--------	-------------------------------	-----------------------------

7. Gợi ý mô hình dữ liệu

Bảng	Trường chính	Mục đích
User	id, email, passwordHash, role, status, createdAt	Tài khoản người dùng và admin.
ScanRequest	id, userId, inputType, rawInput, normalizedInput, createdAt	Mỗi lần người dùng gửi dữ liệu kiểm tra.
RiskResult	id, scanRequestId, score, level, reasons, recommendations	Kết quả chấm điểm và giải thích.
RiskEntity	id, entityType, value, riskLevel, source, status	Domain, URL, phone, bank account, keyword rủi ro.
RiskRule	id, code, conditionType, weight, description, enabled	Bộ luật chấm điểm có thể cấu hình.
ScamReport	id, userId, entityType, value, evidence, status, reviewedBy	Báo cáo lừa đảo do người dùng gửi.
AuditLog	id, actorId, action, targetType, targetId, createdAt	Lưu thao tác quan trọng của admin/người dùng.

8. Vì sao đề tài không bị trùng hoàn toàn?

Các nền tảng đã có thường rất mạnh ở một mảng cụ thể: Google Safe Browsing mạnh về URL blacklist quy mô lớn, VirusTotal mạnh về tổng hợp nhiều engine, PhishTank mạnh về cộng đồng phishing, Tín Nhiệm Mạng/nTrust mạnh về bối cảnh Việt Nam. Tuy nhiên, khóa luận không đặt mục tiêu cạnh tranh với các nền tảng đó.

Điểm hợp lý của đề tài là xây dựng một hệ thống học thuật hoàn chỉnh bằng Java Backend, có phân tích yêu cầu, thiết kế cơ sở dữ liệu, thiết kế API, rule engine, dashboard, báo cáo, kiểm thử và triển khai. Sản phẩm kết hợp nhiều nhóm dữ liệu: link, form, tin nhắn, số điện thoại, số tài khoản và báo cáo cộng đồng.

Yếu tố	Sản phẩm đã có	Đề tài khóa luận
Quy mô dữ liệu	Rất lớn, có dữ liệu thật và đội ngũ vận hành.	Dữ liệu mẫu/giả lập và một số nguồn công khai nếu phù hợp.
Mục tiêu	Bảo vệ người dùng hoặc cung cấp threat intelligence thực tế.	Thể hiện quy trình phát triển phần mềm và năng lực Java Backend.
Phạm vi	Có thể chuyên sâu một mảng như URL, blacklist, mobile app.	Kết hợp URL + form + tin nhắn + phone/account + report trong một demo.
Kỹ thuật	Có thể dùng thuật toán nội bộ, ML, dữ liệu lớn.	Rule Engine, database, web scanner an toàn, dashboard, report, testing.

9. Phạm vi an toàn và đạo đức khi triển khai

- Không tấn công, khai thác lỗ hổng hoặc quét sâu vào website thật.
- Không lưu mật khẩu, OTP, số thẻ hoặc dữ liệu nhạy cảm của người dùng.
- Chỉ kiểm tra thông tin công khai: URL, domain, redirect, header, SSL, HTML/form công khai.
- Thông báo kết quả là 'đánh giá rủi ro', không khẳng định pháp lý rằng một cá nhân/tài khoản chắc chắn lừa đảo nếu chưa có kiểm duyệt.
- Các báo cáo cộng đồng phải có trạng thái xác minh và cơ chế khiếu nại/chỉnh sửa để giảm tố cáo sai.

10. Kết luận đề xuất cho khóa luận

Từ các hệ thống đã có và các hướng nghiên cứu liên quan, đề tài nên chọn hướng xây dựng nền tảng cảnh báo rủi ro lừa đảo trực tuyến đa nguồn dữ liệu. Trọng tâm không phải là phát minh thuật toán hoàn toàn mới, mà là thiết kế và triển khai một hệ thống phần mềm hoàn chỉnh bằng Java Backend, có khả năng xử lý nghiệp vụ thực tế.

Các kỹ thuật nên dùng trong phiên bản khóa luận là: blacklist/whitelist, báo cáo cộng đồng, Rule Engine, phân tích URL/domain, kiểm tra redirect/HTTPS/header, phân tích HTML/form bằng jsoup, phân tích tin nhắn giao dịch bằng keyword/pattern và dashboard quản trị.

Các kỹ thuật nâng cao như AI/ML, OCR, browser extension, tích hợp threat intelligence API nên được trình bày ở phần hướng phát triển mở rộng để đề tài vừa sức nhưng vẫn có chiều sâu.

11. Tài liệu tham khảo

Các nguồn dưới đây là nguồn công khai được dùng để tổng hợp nội dung và đánh số trích dẫn trong tài liệu.

Mã	Nguồn	Nội dung tham khảo	URL
[1]	Google Safe Browsing	Google Safe Browsing - Overview / API reference	https://developers.google.com/safe-browsing/reference
[2]	PhishTank	PhishTank FAQ and public API description	https://www.phishtank.net/faq.php
[3]	VirusTotal	VirusTotal API v3 Overview and Results Reports	https://docs.virustotal.com/reference/overview
[4]	VirusTotal Community	VirusTotal community reputation explanation	https://docs.virustotal.com/docs/results-reports
[5]	ChongLuaDao	ChongLuaDao official website	https://chongluadao.vn/
[6]	Tín Nhiệm Mạng	Danh sách đen website/mạng xã hội giả mạo	https://tinnhiemmang.vn/website-lua-dao
[7]	Tín Nhiệm Mạng	Tính năng tra cứu tài khoản	https://tinnhiemmang.vn/tin-nhiem-mang-ra-mat-tinh-nang-tra-cuu-tai-khoan-thu-ngay
[8]	nTrust	nTrust official website	https://ntrust.vn/
[9]	ScamAdviser	ScamAdviser homepage	https://www.scamadviser.com/home
[10]	CheckPhish	CheckPhish phishing link checker	https://checkphish.bolster.ai/
[11]	OWASP	Unvalidated Redirects and Forwards Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html
[12]	OWASP	HTTP Security Response Headers Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers_Cheat_Sheet.html
[13]	jsoup	jsoup Java HTML parser official site	https://jsoup.org/
[14]	PhishMatch	PhishMatch: A Layered Approach for Effective Detection of Phishing URLs	https://arxiv.org/abs/2112.02226
[15]	WebPhish	Look Before You Leap: Detecting Phishing Web Pages by Exploiting Raw URL and HTML Characteristics	https://arxiv.org/abs/2011.04412
[16]	PhishChain	PhishChain: A Decentralized and Transparent System to Blacklist Phishing URLs	https://arxiv.org/abs/2202.07882
[17]	VirusTotal Study	A Large Scale Study and Classification of VirusTotal Reports on Phishing and Malware URLs	https://arxiv.org/abs/2205.13155